

1.5 Alkalmazási támadások

2025. október 12., vasárnap 21:49

1.5 Alkalmazási támadások

Görgetsen a kezdéshez



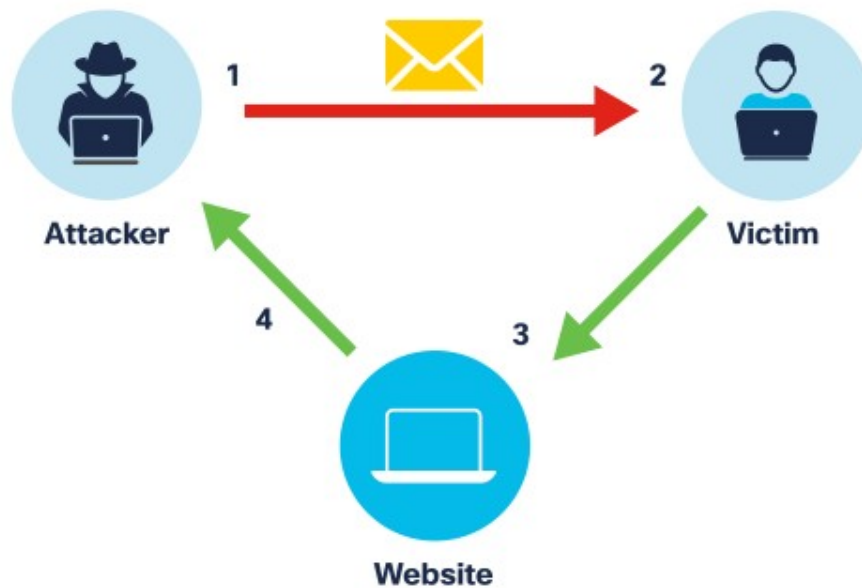
1.5.1 Avatar

A webes alkalmazásokon keresztül végrehajtott támadások egyre gyakoribbak. Ezek közé tartozik a kiberbűnözők, akik kihasználják a webalapú alkalmazások kódolásának sebezhetőségeit, hogy hozzáférjenek egy adatbázishoz vagy szerverhez. Vessünk egy pillantást néhány példára.

1.5.2 Webhelyek közötti szkriptek

A webhelyek közötti parancsfájlok futtatása (XSS) számos webalkalmazásban gyakori biztonsági rés. Így működik:

1. A kiberbűnözők kihasználják az XSS sebezhetőségét azáltal, hogy rosszindulatú kódot tartalmazó szkripteket fecskendeznek be egy weboldalra.
2. A weboldalt az áldozat éri el, és a rosszindulatú szkriptek tudtukon kívül átadják a böngészőjüknek.
3. A rosszindulatú szkript hozzáférhet a felhasználóval kapcsolatos cookie-khoz, munkamenet-tokenekhez vagy egyéb érzékeny információkhoz, amelyeket visszaküld a kiberbűnözőnek.
4. Ezekkel az információkkal felvértezve a kiberbűnöző megszemélyesítheti a felhasználót.



1.5.3 Code Injection

A legtöbb modern webhely adatbázist, például SQL-adatbázist vagy XML-adatbázist használ az adatok tárolására és kezelésére. Az injektálós támadások ezen adatbázisok gyengeségeinek kihasználására töreksenek.

Válassza ki a fejléceket, ha többet szeretne megtudni az injektálós támadások néhány gyakori típusáról.

expand_less

XML-injektálási támadás

Az XML-injektálási támadás megrongálhatja az XML-adatbázis adatait, és veszélyeztetheti a webhely biztonságát.

Úgy működik, hogy megzavarja az alkalmazás XML-adatainak vagy a felhasználó által beírt lekérdezések feldolgozását.

A kiberbűnözők manipulálhatják ezt a lekérdezést úgy, hogy igényeiknek megfelelően programozzák. Ez hozzáférést biztosít számukra az adatbázisban tárolt összes érzékeny információhoz, és lehetővé teszi számukra, hogy tetszőleges számú változtatást hajtsanak végre a weboldalon.

expand_less

SQL-injektálási támadás

A kiberbűnözők SQL-injekciós támadást hajthatnak végre webhelyek vagy bármely SQL-adatbázis ellen, ha rosszindulatú SQL-utasítást illesztenek be egy beviteli mezőbe.

A támadás egy olyan biztonsági rést használ ki, amelyben az alkalmazás nem szűri megfelelően a felhasználó által bevitt adatokat az SQL-utasítás karaktereihez.

Ennek eredményeként a kiberbűnöző jogosulatlan hozzáférést kaphat az adatbázisban tárolt információkhoz, amelyekből meghamisíthatja a személyazonosságot, módosíthatja a meglévő adatokat, megsemmisítheti az adatokat, vagy akár magának az adatbázis-kiszolgálónak az adminisztrátorává válhat.

expand_less

DLL-injektálási támadás

A dinamikus csatolású könyvtár (DLL) fájl egy olyan könyvtár, amely kódot és adatokat tartalmaz egy adott tevékenység végrehajtásához a Windows rendszerben. Az alkalmazások ezt a fájltypust nem beépített funkciók hozzáadására használják, amikor ezt a tevékenységet végre kell hajtaniuk.

A DLL-injektálás lehetővé teszi a kiberbűnözők számára, hogy becsapják az alkalmazást, hogy rosszindulatú DLL-fájlt hívjanak meg, amely a célfolyamat részeként fut.

expand_less

LDAP-injektálási támadás

Az LDAP egy nyílt protokoll a címtárszolgáltatásokhoz való felhasználói hozzáférés hitelesítésére.

Az LDAP-injektálós támadás kihasználja a bemeneti érvényesítési biztonsági réseket azáltal, hogy lekérdezéseket injektál és hajt végre az LDAP-kiszolgálókra, lehetőséget adva a kiberbűnözőknek arra, hogy bizalmas információkat nyerjenek ki a szervezet LDAP-címtárából.

1.5.4 Puffer túlcsordulás

A pufferek az alkalmazáshoz lefoglalt memóriaterületek. Puffertúlcsordulás akkor fordul elő, ha az adatokat a puffer határain túlra írják. Az adatok pufferhatárain túli módosításával az alkalmazás hozzáférhet a más folyamatok számára lefoglalt memóriához. Ez a rendszer összeomlásához vagy adatbiztonsághoz vezethet, vagy a jogosultságok eskalációját biztosíthatja.

Ezek a memóriahibák a támadóknak teljes irányítást is biztosíthatnak a célpont eszköze felett.

Például a támadó megváltoztathatja egy sebezhető alkalmazás utasításait, miközben a program betöltődik a memóriába, és ennek eredményeként rosszindulatú programokat telepíthet, és hozzáférhet a belső hálózathoz a fertőzött eszközről.





1.5.5 Avatar

Tudtad, hogy a Carnegie Mellon Egyetem kutatása szerint a számítógépes programok kihasználásának közel fele valamilyen puffertúlsordulásból származik?

1.5.6. Távoli kódfuttatások

A távoli kódfuttatás lehetővé teszi a kiberbűnözők számára, hogy kihasználják az alkalmazás biztonsági réseit és végrehajtsanak bármilyen parancsot az alkalmazást a céleszközön futtató felhasználó jogosultságaival.

A jogosultságeszkaláció egy operációs rendszer vagy szoftveralkalmazás hibáját, tervezési hibáját vagy hibás konfigurációját használja ki, hogy hozzáférjen az általában korlátozott erőforrásokhoz. Válassza ki a képet, ha többet szeretne megtudni a Metasploit Projectről és a közösség fehér kalapos kiberbiztonsági eszközeiről.



touch_app

A Metasploit Project egy számítógépes biztonsági projekt, amely információkat nyújt a biztonsági résekről, és segíti a behatolási tesztelést. Az általuk kifejlesztett eszközök között szerepel a Metasploit Framework, amely távoli célpont elleni kihasználó kód fejlesztésére és végrehajtására használható.

A Meterpreter különösen a Metasploiton belüli hasznos teher, amely lehetővé teszi a felhasználók számára, hogy átvegyék az irányítást a célpont eszköze felett azáltal, hogy saját kiterjesztéseiket írják, és ezeket a fájlokat feltöltik az eszközön futó

folyamatba. Ezek a fájlok a memóriából töltődnek be és futnak le, így soha nem érintik a merevlemezt. Ez azt jelenti, hogy az ilyen fájlok a víruskereső észlelésének radarja alatt repülnek.

A Meterpreter rendelkezik egy modullal a távoli rendszer webkamerájának vezérlésére is. Miután a Meterpreter telepítve van a céleszköze, a Metasploit felhasználó megtekintheti és rögzítheti a képeket a célpont webkamerájáról.

visszajátszás

1.5.7 Egyéb alkalmazási támadások

Minden információ, amelyet a támadó egy megcélzott rendszerről vagy alkalmazásról kap, értékes fegyverként használható veszélyes támadás indításához.

A fejlécek kiválasztásával többet szeretne megtudni az alkalmazástámadások más típusairól.

expand_less

Telephelyek közötti kérelmek hamisítása (CSRF)

A CSRF egy webhely rosszindulatú kihasználását írja le, amikor a felhasználó böngészője jogosulatlan parancsokat küld egy megbízható webalkalmazásnak.

Egy rosszindulatú webhely speciálisan kialakított képcímkéken, rejtett űrlapokon vagy JavaScript-kéréseken keresztül továbbíthatja ezeket a parancsokat – amelyek mindegyike a felhasználó tudta nélkül működhet.



expand_less

Versenyhelyzeti támadás

Az ellenőrzési időszak (TOC) vagy a használat ideje (TOU) támadásnak is nevezett versenyhelyzeti támadás akkor következik be, amikor egy adott sorrendben végzett feladatok kezelésére tervezett számítástechnikai rendszer két vagy több művelet egyidejű végrehajtására kényszerül.

Például az operációs rendszerek szálakból állnak – a folyamat végrehajtásához szükséges programutasítások legkisebb sorozatából. Ha két vagy több szál fér hozzá a megosztott adatokhoz, és pontosan egyszerre próbálja módosítani azokat, versenyhelyzeti támadás történik.



expand_less

Nem megfelelő bemenetkezelési támadás

A nem megfelelően ellenőrzött felhasználó által bevitt adatok hatással lehetnek a program adatfolyamára, és kritikus biztonsági réseket okozhatnak a rendszerekben és alkalmazásokban, amelyek puffertúlcsordulást vagy SQL-injektálási támadásokat eredményeznek.



expand_less

Hibakezelési támadás

A támadók hibaüzenetek segítségével kinyerhetnek bizonyos információkat, például a belső rendszerek gazdagépnevét és az adott webszerveren található könyvtárakat vagy fájlokat, valamint adatbázis-, tábla- és mezőneveket, amelyek felhasználhatók az SQL-injektálási támadások létrehozására.



expand_less

Alkalmazásprogramozási felület (API) támadás

Az API felhasználói választ küld a rendszernek, és visszaküldi a rendszer válaszát a felhasználónak. API-támadás akkor történik, ha egy kiberbűnöző visszaél egy API-végponttal.



expand_less

Támadás visszajátszása

Ez egy olyan helyzetet ír le, amikor egy támadó rosszindulatúan vagy csalárd módon megismétli vagy késlelteti az érvényes adatátvitelt, aki elfogja, módosítja és újra elküldi az adatokat, hogy a fogadó azt tegye, amit akar.



expand_less

Címtárbejárési támadás

A címtárbejárás akkor történik, ha a támadó a webszerveren található fájlokat a webhely könyvtárán kívül tudja olvasni. A támadó ezután felhasználhatja ezeket az információkat érzékeny információkat tartalmazó szerverkonfigurációs fájlok letöltésére, potenciálisan további szerver sebezhetőségeket tárhat fel, vagy akár átveheti az irányítást a szerver felett!



expand_less

Erőforrás-kimerülési támadások

Ezek a támadások olyan számítógépes biztonsági kihasználások, amelyek összeomlanak, lefagynak vagy más módon zavarják a megcélzott programot vagy rendszert. Ahelyett, hogy túlterhelnék a hálózati sávszélességet, mint egy DoS-támadás, az erőforrás-kimerülési támadások túlterhelik a cél szerverén rendelkezésre álló hardvererőforrásokat.



1.5.8 Mit gondolsz?

Guru kikérte a véleményedet. Úgy tűnik, hogy egy támadó a @Apollo online üzenetküldő szolgáltatásának sebezhetőségét célozta meg, amely a különböző webhelyeken dolgozó alkalmazottak közötti kommunikáció megkönnyítésére szolgál. Amikor egy alkalmazott hanghívást kezdeményez, az elárasztja az alkalmazás memóriáját, így a támadó hatékonyan irányíthatja az alkalmazott eszközét. Milyen típusú támadás ez? Válassza ki a helyes választ, majd a Küldés lehetőséget.

`radio_button_unchecked`

Webhelyek közötti szkriptek

`radio_button_unchecked`

Erőforrás-kimerülési támadás

`radio_button_unchecked`

Távoli kódfuttatás

`radio_button_unchecked`

Puffertúlcsordulás

`ElőterjesztVisszajelzés megjelenítése`

1.5.9 Védekezés az alkalmazástámadások ellen

Számos műveletet végezhet az alkalmazástámadások elleni védekezéshez. Néhányat ezek közül itt talál.

- Az alkalmazástámadások elleni első védelmi vonal a szilárd kód írása.
- A körütekintő programozási gyakorlat magában foglalja a függvényen kívülről érkező összes bemenet ellenséges kezelését és érvényesítését.
- Tartsa naprakészen az összes szoftvert, beleértve az operációs rendszereket és az alkalmazásokat is, és ne hagyja figyelmen kívül a frissítési kéréseket. Ne feledje, hogy nem minden program frissül automatikusan.



1.5.10 Avatar

Az e-mailt világszerte emberek milliárdjai használják, és ennek eredményeként jelentős sebezhetőséggé vált a felhasználók és a szervezetek számára.

Görögessen lefelé, ha többet szeretne megtudni néhány gyakori e-mail- és böngészőtámadásról.

1.5.11 Spam

A spam, más néven levélszemét, egyszerűen kéretlen e-mail. A legtöbb esetben ez egy reklámmódszer. Azonban sok spamet küldenek tömegesen a vírusokkal vagy férgekkel fertőzött számítógépek – és gyakran rosszindulatú hivatkozásokat, rosszindulatú programokat vagy megtévesztő tartalmakat tartalmaznak, amelyek célja, hogy rávegyék a címzetteket érzékeny információk, például társadalombiztosítási szám vagy bankszámlaadatok nyilvánosságra hozatalára.

Szinte minden e-mail szolgáltató kiszűri a spamet, de továbbra is sávszélességet fogyaszt. És még ha biztonsági funkciókat is implementált, előfordulhat, hogy a spam eljut Önhöz. Figyeljen a spam következő mutatóira:

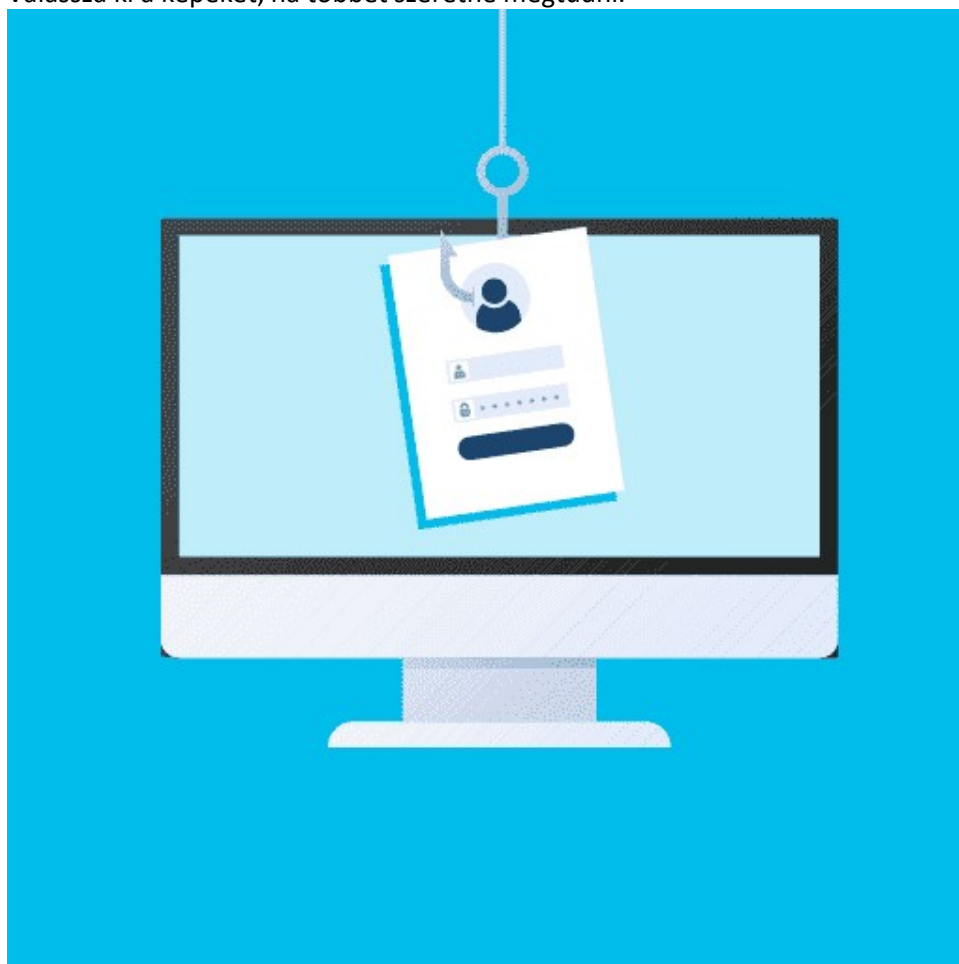
- Az e-mailnek nincs tárgysora.
- Az e-mail arra kéri, hogy frissítse fiókadatait.
- Az e-mail szövege hibásan írt szavakat vagy furcsa írásjeleket tartalmaz.
- Az e-mailben található linkek hosszúak és/vagy rejtélyesek.
- Az e-mail úgy néz ki, mint egy törvényes vállalkozás levelezése, de vannak apró különbségek - vagy olyan információkat tartalmaz, amelyek nem tűnnek relevánsnak az Ön számára.
- Az e-mail arra kéri, hogy nyisson meg egy mellékletet, gyakran sürgősen.

Ha olyan e-mailt kap, amely egy vagy több ilyen jelzőt tartalmaz, ne nyissa meg az e-mailt vagy a mellékleteket. Számos szervezet rendelkezik olyan e-mail szabállyal, amely megköveteli az alkalmazottaktól, hogy jelentsék az ilyen típusú e-mailek kézhezvételét a kiberbiztonsági csapatuknak további vizsgálat céljából. Ha kétségei vannak, mindig jelentse.

1.5.12 Adathalászat

Az adathalászat a csalárd tevékenység egyik formája, amelyet gyakran használnak személyes adatok ellopására.

Válassza ki a képeket, ha többet szeretne megtudni.



touch_app

Adathalászat

Adathalászat akkor fordul elő, ha a felhasználóval e-mailben vagy csevegőüzenetben – vagy bármilyen más módon – kapcsolatba lép valaki, aki legitim személynek vagy szervezetnek álcázza magát. A cél az, hogy rávegye a címzettet, hogy rosszindulatú programokat telepítsen az eszközére, vagy ossza meg személyes adatait, például bejelentkezési adatait vagy pénzügyi adatait.

Például kap egy e-mailt, amelyben gratulálunk a nyereményhez. Úgy néz ki, mintha egy jól ismert kiskereskedelmi üzletből küldték volna, és arra kéri, hogy kattintson

egy linkre a nyeremény igényléséhez. Ez a link valójában egy hamis webhelyre irányíthatja át, amely személyes adatainak megadását kéri, vagy akár vírust is telepíthet az eszközére.

visszajátszás



touch_app

Lándzsás adathalászat

A célzott támadás, a lándzsás adathalászat személyre szabott e-maileket küld egy adott személynek a támadó által róluk ismert információk alapján – amelyek lehetnek érdeklődési körük, preferenciáik, tevékenységeik és munkaprojektjeik.

Például egy kiberbűnöző kutatása során felfedezi, hogy egy adott autómoddelt szeretne vásárolni. A kiberbűnöző csatlakozik egy autós vitafórumhoz, amelynek tagja, hamisít egy autóeladási ajánlatot, és küld egy e-mailt, amely tartalmaz egy linket az autó képeinek megtekintéséhez. Amikor rákattint a linkre, tudtán kívül rosszindulatú programokat telepít az eszközére.

visszajátszás

1.5.13 Vishing, Pharming és Bálnavadászat

A bűnözők számos technikát alkalmaznak, hogy megpróbáljanak hozzáférni az Ön személyes adataihoz.

Válassza ki a fejléceket, ha többet szeretne megtudni néhány gyakori csalásukról.

expand_less

Vishing

Az ilyen típusú támadások során a bűnözők hangkommunikációs technológiát használnak, hogy arra

ösztönözzék a felhasználókat, hogy adjanak meg információkat, például hitelkártyaadataikat. A bűnözők meghamisíthatják a telefonhívásokat az internetprotokollon keresztüli hangátviteli protokoll (VoIP) segítségével, vagy rögzített üzeneteket hagyhatnak, hogy azt a benyomást keltsék, hogy legitim hívók.



expand_less

Pharming

Ez a fajta támadás szándékosan félreirányítja a felhasználókat egy hivatalos webhely hamis verziójára. A felhasználókat becsapják, hogy elhiggyék, hogy egy legitim webhelyhez kapcsolódnak, és beírják hitelesítő adataikat a csaló webhelyre.



expand_less

Bálnavadászat

A bálnavadászat egy adathalász támadás, amely magas rangú személyeket, például egy szervezet felső vezetőit, politikusokat és hírességeket céloz meg.



1.5.14 Elment az adathalászat...

@Apollo számos biztonsági szabállyal rendelkezik, amelyek megkövetelik az alkalmazottaktól, hogy jelentsenek minden gyanús tevékenységet a kiberbiztonsági csapatnak további vizsgálat céljából.

A Guru megkért, hogy tekintse át a közelmúltban végzett tevékenységeket, hogy lássa, van-e olyan biztonsági probléma. Meg tudja határozni, hogy az egyes forgatókönyvek milyen típusú támadást írnak le?

Válasszon ki egy lehetőséget az egyes legördülő menükből, majd a Küldés lehetőséget.

Egy alkalmazott e-mailt kapott, amely úgy nézett ki, mintha egy @Apollo beszállítótól érkezett volna, és arra kérte, hogy kattintson egy linkre a kedvezmény igényléséhez

Kérjük, válasszon egy lehetőséget

arrow_drop_down

Egy alkalmazott automatikus telefonhívást kapott a banktól, amelyben arról tájékoztatták, hogy @Apollo számláját feltörték, és hogy a jelszó visszaállításához egy adott számot kell felhívnia

Kérjük, válasszon egy lehetőséget

arrow_drop_down

Egy alkalmazott SMS-t kapott, amelyben arról tájékoztatták, hogy @Apollo egyik szoftver-előfizetése lejár, és azonnal frissítenie kell az adatokat

Kérjük, válasszon egy lehetőséget

arrow_drop_down

ElőterjesztVisszajelzés megjelenítése

1.5.15 Védekezés az e-mailek és a böngészők támadásai ellen

Számos műveletet tehet az e-mailek és a böngésző támadásai elleni védekezés érdekében. A legfontosabbak közül néhányat itt vázolunk fel.

- Nehéz megállítani a spamet, de vannak módok a hatásainak csökkentésére:
 - A legtöbb internetszolgáltató kiszűri a levélszemetet, mielőtt az elérné a felhasználó postaládáját.
 - Számos víruskereső és e-mail szoftver automatikusan észleli és eltávolítja a veszélyes spameket az e-mail postaládájából.
 - A szervezeteknek tájékoztatniuk kell az alkalmazottakat a kórtelen e-mailek veszélyeiről, és tudatosítaniuk kell bennük a mellékletek megnyitásának veszélyeit.

- Soha ne feltételezze, hogy az e-mail melléletek biztonságban vannak, még akkor sem, ha megbízható kapcsolattartótól származnak. Mindig olvassa be a tartozékokat, mielőtt kinyitná őket.
- Legyen tagja az adathalászat elleni munkacsoportnak (APWG). Ez egy nemzetközi vállalatsszövetség, amely az adathalászatból és az e-mailek hamisításából eredő személyazonosság-lopások és csalások kiküszöbölésére összpontosít.
- Minden szoftvert naprakészen kell tartani, és a legújabb biztonsági javításokat kell alkalmazni az ismert biztonsági rések elleni védelem érdekében.



1.5.16 Avatar

Pfuj! Ez sok mindent be kell fogadni. A kiberbűnözők számos taktikát alkalmazhatnak, hogy megszerezzék a kívánt információkat. És még nem végeztünk!
Görgessen le, és folytassa...

1.5.17 Van még...

Válassza ki a fejléceket, hogy további információkat jelenítsen meg a kiberbűnözők által indított egyéb gyakori támadásokról.

expand_less

Fizikai támadások

A fizikai támadások szándékos, sértő tevékenységek, amelyeket a szervezet infrastruktúrájának vagy hardverének megsemmisítésére, felfedésére, megváltoztatására, letiltására, ellopására vagy jogosulatlan hozzáférésre használnak.

Példák a fizikai támadásokra:

- Rosszindulatú programok betöltése USB flash meghajtóra, amely megfertőzi az eszközt, ha csatlakoztatva van.
- Kábelek és csatlakozók, például általános USB-kábelek, mobilkészítők töltőkábeleit és fali vagy hálózati adapterek csatlakoztatása fejlett technológiával, például vezeték nélküli chippel, hogy a támadó irányíthassa az eszközt, vagy utasításokat adhasson neki.
- Adatok másolása vagy lefoglalása hitel- vagy betéti kártyáról egy speciális terminál segítségével klónozott kártya létrehozásához, amellyel jogosulatlan hozzáférést lehet szerezni az áldozat számláihoz.

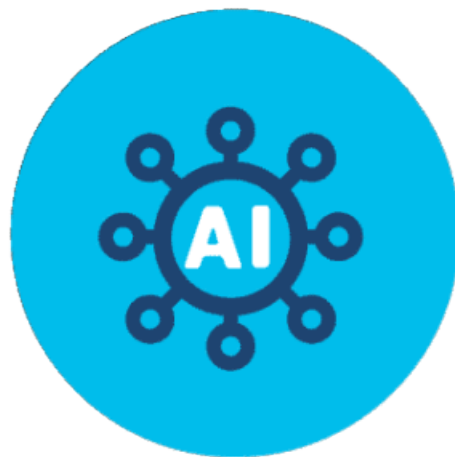


expand_less

Ellenséges mesterséges intelligencia támadások

A gépi tanulás egy olyan automatizálási módszer, amely lehetővé teszi az eszközök számára, hogy elemzéseket végezzenek és feladatokat hajtsanak végre anélkül, hogy erre külön programoznák őket. Számos ma használt alkalmazást működtet, például a webes keresést, a fényképcímkézést, a spamészlelést, a videomegfigyelést, a csalások észlelését és a biztonsági automatizálást.

A gépi tanulás matematikai modelleket használ az eredmények előrejelzésére. Ezek a modellek azonban a bevitt adatoktól függenek. Ha az adatok szennyezettek, az negatív hatással lehet az előre jelzett eredményre. A támadók ezt kihasználhatva támadásokat hajthatnak végre a gépi tanulási algoritmusok ellen. Például szennyezett adatok felhasználásával becsapnak egy autonóm járművet az utcatáblák félreértelmezésére.



expand_less

Ellátási lánc támadások

Számos szervezet kapcsolatba lép egy harmadik féllel a rendszerfelügyelet vagy az alkatrészek és szoftverek vásárlása érdekében. A szervezetek akár külföldi forrásból származó alkatrészekre vagy alkatrészekre is támaszkodhatnak.

A támadók gyakran megtalálják a módját ezeknek az ellátási láncoknak az elfogására. A szoftverek például konkrét támogatási megállapodásokon alapulhatnak, és élettartamuk végének dátumától függhetnek. A dátum módosítása azt jelentheti, hogy egy szervezet már nem jogosult szervizelési és karbantartási támogatásra.



expand_less

Felhőalapú támadások

Ahelyett, hogy saját telephelyükön fejlesztenének rendszereket, egyre több szervezet mozdul el a felhőalapú számítástechnika felé, amint azt ebben a modulban korábban tárgyaltuk.

Előnye, hogy a felhőszolgáltató karbantartja a berendezéseket, de ez számos potenciális fenyegetés előtt is megnyitja a szervezetet. A támadók folyamatosan kihasználják a felhőben tárolt érzékeny adatok, valamint a felhőalapú alkalmazások, platformok és infrastruktúra kihasználásának módjait, amint azt a SaaS, a PaaS és az IaaS esetében is láthattuk.



Forrás: <<https://www.netacad.com/content/noes/1.0/index.html?xAPILaunchKey=e02fb616-7558-4b9d-a8f6-4cfd31edfe34&xAPILaunchService=https://www.netacad.com/adl/content/&lang=en-US&moduleNumber=1#/courses/content/m1/id/b5041a0d3613425391375e7970dd715c>>